PYC

exec

Analise o arquivo em anexo passo a passo e determine ao final: este arquivo é benigno ou é um malware?

Com base na análise detalhada do código fonte e dos componentes embutidos no arquivo anexado, apresento a seguir a decomposição passo a passo do seu funcionamento e a conclusão final sobre sua natureza.

Análise Passo a Passo

1. Arquitetura e Extração de Componentes

O arquivo é um script executável em Python empacotado que atua como um *bootstrap* (instalador automático). Ao ser executado com privilégios de superusuário (`root`), ele verifica o ambiente, cria diretórios de trabalho (`/root/.s/` , `/root/.a/`), configura um ambiente virtual Python (`venv`) e extrai/grava múltiplos scripts auxiliares e arquivos de serviço (`systemd`):

- `run_scan.sh` : Script de automação em Bash que gerencia ciclos contínuos de varredura.
- `ssh_scanner.py` : Ferramenta de força bruta em SSH baseada em multithreading (`paramiko`).
- `monitor_script.py` : Agente de monitoramento, propagação e controle remoto.

Outros utilitários: Scripts de extração de IP/porta (`ip_port_extractor.py`) e filtragem (`filter_files.py`).

2. Varredura de Rede (Reconhecimento)

O script utiliza o utilitário `masscan` para escanear faixas de endereços IP em busca de portas SSH abertas (especificamente as portas `22` e `5522`), operando em alta velocidade e ajustando dinamicamente os parâmetros com base nos núcleos de CPU disponíveis no sistema infectado. Desconhecido

3. Ataque de Força Bruta SSH

Através do script `ssh_scanner.py`, o arquivo realiza ataques de força bruta em larga escala utilizando credenciais pré-definidas e altamente específicas (como os pares de senha `LeitboGi0ro` e `123@@@`) contra os alvos descobertos na etapa de varredura. Os IPs bem-sucedidos são salvos em arquivos de relatório e adicionados automaticamente a uma lista de exclusão (`del.txt`). Desconhecido + 1

4. Propagação Automática e Infecção Secundária (Worm)

O componente `monitor_script.py` monitora continuamente os resultados das invasões bem-sucedidas. Assim que um novo servidor é comprometido via força bruta:

- Conecta-se via SSH ao novo host alvo. Desconhecido
- Faz o *upload* de um payload secundário (`bendi.py`). Desconhecido
- Instala dependências e executa o payload remotamente. Desconhecido
- Instala um agente de controle externo (*komari-agent*) baixado diretamente de um repositório remoto do GitHub (`komari-monitor`). Desconhecido

5. Comunicação com Servidor de Comando e Controle (C2) e Exfiltração

O script possui mecanismos integrados para:

- **Telegram Bot:** Envia relatórios detalhados de infecção, credenciais utilizadas e status dos servidores comprometidos diretamente para um chat do Telegram utilizando um token de API embutido (`7431501378:AAHTIaWSQ1Gcqp5ovhY6-6L1TG8Npubq1Ug`). Desconhecido
- **API Centralizada:** Comunica-se com um servidor externo (`sou.pp.ua`) para registrar os alvos já processados e evitar duplicações de ataques. Desconhecido

6. Persistência e Limpeza

O instalador configura serviços nativos do Linux (`systemd`) para garantir que os módulos de varredura e monitoramento iniciem automaticamente com o sistema (`Restart=always`) e, por fim, **deleta a si mesmo** do disco para apagar rastros após a implantação. Desconhecido

Conclusão Final

Este arquivo é um MALWARE.

Trata-se especificamente de um **Worm de Propagação Automatizada com capacidades de Botnet e Força Bruta**. Ele foi projetado para transformar a máquina

infectada em um nó escravo (*drone*) cujo objetivo é escanear a internet, descobrir servidores mal protegidos, realizar ataques de adivinhação de senha (brute-force) em SSH, infectar novos hosts, reportar o progresso via Telegram e manter persistência oculta no sistema operacional.

Qual é a categoria principal deste malware?

A categoria principal deste malware é a de um **Worm (Verme Informático) auto-propagável**, fortemente combinado com capacidades de **Botnet** e **ferramenta de Força Bruta**.

A sua classificação pode ser dividida nas seguintes vertentes funcionais:

Worm (Propagação Automática): Possui a capacidade autónoma de varrer a rede (através do *masscan*), descobrir novos alvos, injetar *payloads* secundários e infetar novos servidores em cadeia, sem necessidade de controlo manual contínuo.

Botnet / Agente de C2: Integra mecanismos de comunicação com servidores externos (como APIs centralizadas e bots do Telegram) para reportar o sucesso das invasões, sincronizar alvos processados e aguardar diretrizes.

Ataque de Força Bruta: Utiliza módulos automatizados para testar credenciais em larga escala contra serviços SSH expostos na internet, garantindo o acesso inicial aos sistemas comprometidos.